

UNIVERSITY OF DHAKA

Hybrid SIEM and Network Intrusion Detection with Lightweight Behavioral Anomaly Detection for U2R and R2L Attacks

by

Mehedi Hasan Nayan

Exam Roll: H-409 · Registration No: XXXX-XXX-XXX, Session: XXXX-XX

Tawsif Zawad

Exam Roll: H-413 · Registration No: XXXX-XXX-XXX, Session: XXXX-XX

Department of Computer Science and Engineering

Professional Masters in Information and Cyber Security (PMICS)

Declaration

We hereby declare that this project report titled "*Hybrid SIEM and Network Intrusion Detection with Lightweight Behavioral Anomaly Detection for U2R and R2L Attacks*" has been carried out by us under the supervision of Md. Samiul Islam, Instructor, and co-supervision of Palash Roy, Lecturer, Department of Computer Science and Engineering, University of Dhaka. The work is our own and has not been submitted elsewhere for the award of any degree.

Mehedi Hasan Nayan

Exam Roll: H-409

Candidate 1

Tawsif Zawad

Exam Roll: H-413

Candidate 2

Md. Samiul Islam

Instructor, Department of CSE

University of Dhaka

Supervisor

Palash Roy

Lecturer, Department of CSE

University of Dhaka

Co-Supervisor

Abstract

With the rapid growth of networked systems, detecting sophisticated and low-frequency cyber-attacks has become increasingly difficult. Traditional Intrusion Detection Systems and Security Information and Event Management (SIEM) tools rely mainly on rule-based detection: effective for known threats, but weak against rare and stealthy User-to-Root (U2R) and Remote-to-Local (R2L) intrusions.

This project presents a hybrid, cross-platform detection framework that fuses three independent viewpoints - host telemetry (Windows, Ubuntu and macOS collectors), network telemetry (Suricata) and SIEM alerts (Wazuh) - into a single, OS-independent pipeline. Every session is judged three ways: context-aware signature rules, a multi-stage correlation engine (including cross-plane chains that fire only when two viewpoints agree), and a lightweight Isolation Forest that models each machine's normal behaviour across eighteen distinct behavioural features and flags novel deviations. Findings are mapped to MITRE ATT&CK and explained to the analyst.

The approach is validated on real recorded attacks (136 of 137 public EVTX attack samples detected, 99.3%), on the standard NSL-KDD benchmark (ROC area 0.944), and at scale on the CERT r4.2 insider-threat dataset (1,000 realistic users and 330k sessions, ROC area 0.81). The benchmarks also confirm the central motivation: unsupervised anomaly detection on network data alone is weak on exactly the rare R2L and U2R classes this thesis targets, which is why the host, SIEM and correlation layers are added on top. The result is a practical, explainable and deployable system that improves rare-attack coverage while keeping the false-alarm rate low.

Acknowledgements

We would like to express our sincere gratitude to our supervisor, Md. Samiul Islam, and our co-supervisor, Palash Roy, of the Department of Computer Science and Engineering, University of Dhaka, for their guidance and encouragement throughout this work. We also thank the Department, the PMICS programme, and our families for their continued support.

Contents

1 Introduction	6
1.1 Motivations	6
1.2 Objectives	6
1.3 Contributions	6
1.4 Challenges	7
1.5 Organization	7
2 Related Works	8
2.1 Problem of Existing Systems	8
3 Proposed Methodologies	10
3.1 Three Detection Layers	10
3.2 Three Data Planes and Cross-Plane Correlation	11
3.3 Context-Aware Detection	11
3.4 Behavioural Feature Engineering	11
3.5 Anomaly Model and MITRE Mapping	11
3.6 Process Flow	12
4 Implementation	13
4.1 Tools and Technologies	13
4.2 Collectors and Normalisation	13
4.3 Detectors, Correlation and Allowlist	13
4.4 Model, Modes and Dashboard	13
5 Experimental Results	15
5.1 Results Analysis	15
5.2 Summary of the Experimental Results	18
6 Conclusions	19
6.1 Research Summary	19
6.2 Future Work Plan	19
Bibliography	20

Chapter 1

Introduction

Modern organisations rely on SIEM and IDS tools to monitor and defend their systems. While efficient at recognising known attack signatures, these tools struggle with low-frequency, stealthy attacks such as U2R and R2L, which exploit systems in subtle ways that resemble ordinary activity.

1.1 Motivations

Every computer produces thousands of log lines a day - logins, process launches, file accesses, device events. Dangerous intrusions hide inside this flood and rarely announce themselves. Two classes are especially hard to catch and are the focus of this work:

- **U2R (User-to-Root)**: a user who already holds a normal account quietly escalates to administrator privileges.
- **R2L (Remote-to-Local)**: an outsider guesses or steals credentials and enters as though authorised.

Signature-based tools only know yesterday's attacks and produce high false-negative rates on these rare classes; pure anomaly detectors flag the unusual but cannot explain what it means. A hybrid that combines both, across several independent data sources, is needed.

1.2 Objectives

- Design a hybrid detection framework that combines rule-based SIEM detection with lightweight anomaly detection.
- Improve the detection of rare U2R and R2L attacks.
- Evaluate the approach using both real logs and a benchmark dataset (NSL-KDD).
- Map detected behaviour to the MITRE ATT&CK framework for structured, standardised reporting.

1.3 Contributions

- A single, resource-efficient framework that integrates **Wazuh** (SIEM), **Suricata** (network IDS), an **Isolation Forest** anomaly model and **MITRE ATT&CK** mapping - an integration not previously combined for U2R/R2L in one deployable tool.
- **Context-aware detection**: a process is never judged by name alone; the command line, parent process, execution path, digital signature and surrounding activity are all weighed, sharply cutting false alarms.
- **Cross-plane correlation**: attack chains that fire only when two independent viewpoints agree (e.g. an obfuscated host command AND a malicious-server contact on the wire = confirmed C2).
- **Explainable behavioural anomaly detection (UEBA)**: eighteen distinct behavioural features and a per-user deviation explanation in standard-deviation terms, with a recent-trend view.
- **Cross-platform** collection (Windows, Ubuntu, macOS) behind one OS-independent pipeline, packaged as a runnable per-OS demo with a self-contained dashboard.

1.4 Challenges

- Detecting rare classes (U2R/R2L) that statistically resemble normal activity, especially at the network-flow level.
- Keeping false positives low so that analysts trust the alerts.
- Normalising heterogeneous telemetry from three operating systems and two external sensors into one common representation.
- Making machine-learning verdicts explainable rather than opaque.

1.5 Organization

The report is organised as follows. Chapter 2 reviews related work and identifies the research gap. Chapter 3 presents the proposed methodology and architecture. Chapter 4 describes the implementation. Chapter 5 reports and analyses the experimental results. Chapter 6 concludes and outlines future work.

Chapter 2

Related Works

This chapter surveys closely related systems and research that inform the design of the proposed framework, with particular emphasis on the rare U2R and R2L classes.

Wazuh with Machine-Learning Enhancement

Chamkar et al. (2025) enhanced Wazuh SIEM with Random Forest and DBSCAN to reduce its high false-positive rate, reaching 97.2% and 91.06% accuracy respectively at sub-100 ms latency. However, they did not evaluate U2R/R2L specifically and used a controlled enterprise simulation - the gap this project targets [1].

Hybrid Ensemble IDS on NSL-KDD

Mills et al. (2024) proposed a supervised stacking ensemble reaching 99.84% accuracy on NSL-KDD, yet U2R detection remained weak ($F1 = 62.5\%$) due to severe class imbalance - reinforcing the need for an unsupervised complementary layer [2].

Isolation Forest for Anomaly Detection

Bello et al. (2024/25) showed Isolation Forest reaching 95.2% detection with a 4.7% false-positive rate on NSL-KDD, outperforming One-Class SVM and Local Outlier Factor, with sub-linear complexity suitable for real-time, label-free deployment. This directly motivates our choice of Isolation Forest [3].

Suricata versus Snort

Shah and Issac (2018), confirmed by a 2024 benchmark, found Suricata scales better through multi-threading but, like Snort, is purely signature-based and cannot detect zero-day behaviour - hence our pairing of Suricata with anomaly detection [4, 5].

MITRE ATT&CK-Aligned; SIEM Evaluation

Winkler and Sharma (2025) evaluated Wazuh against Atomic Red Team across four tactics (~85% overall), showing that ATT&CK mapping greatly improves alert interpretability but that rule-based SIEM alone is insufficient for subtle behaviour - precisely the U2R/R2L scenario [6].

Deep Hybrid IDS

Lv and Ding (2024) combined K-Means with a CNN+LSTM model, strong on DoS/Probe but heavy on resources and reliant on labelled data. We deliberately choose the lighter Isolation Forest for comparable anomaly coverage at far lower cost [7].

2.1 Problem of Existing Systems

- Depend mostly on predefined rules and static signatures.
- Fail to detect unknown or rare attack patterns (U2R, R2L).
- Produce high false-negative rates for low-frequency classes.
- Lack adaptive learning for evolving threats, and rarely explain their verdicts.

Research gap. No existing study simultaneously integrates Wazuh SIEM, Suricata network monitoring, Isolation Forest anomaly detection and MITRE ATT&CK mapping into a unified, resource-efficient, cross-platform framework that explicitly targets U2R and R2L. This project addresses all four dimensions in a practical, deployable architecture.

Chapter 3

Proposed Methodologies

The system reads a computer's activity, adds meaning to each record, notices when several records together tell an attack story, and separately learns each machine's ordinary behaviour so it can spot a day that is not ordinary. Figure 3.1 shows the overall design.

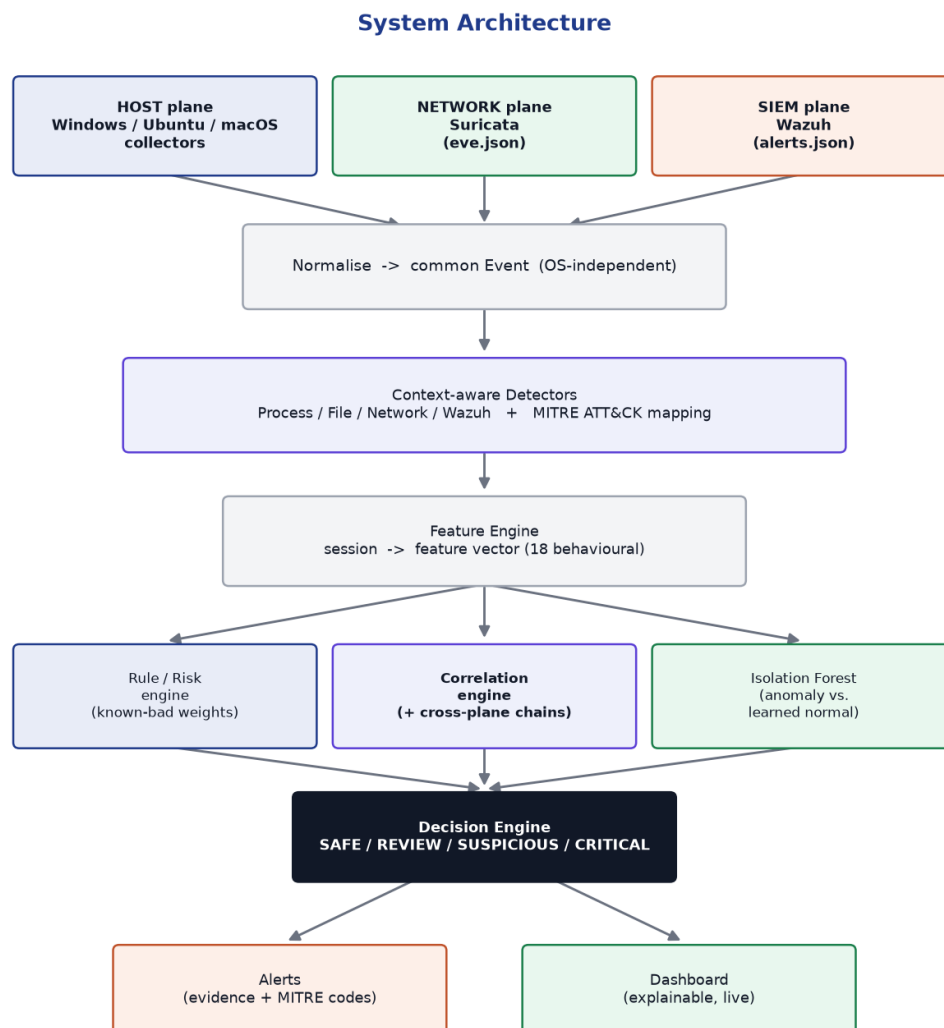


Figure 3.1: System architecture. Three data planes feed one OS-independent pipeline, judged by three engines and fused into a single explainable verdict.

3.1 Three Detection Layers

- **Rules (signatures)** recognise known-bad patterns in commands, paths and files - encoded PowerShell, LOLBin downloads, ransomware wiping backups, credential theft. Precise and explainable, but only know what they were taught.

- **Correlation** joins several weak signals into one named attack chain, raising confidence enough to justify a CRITICAL verdict.
- **Machine learning (Isolation Forest)** learns each machine's normal behaviour and flags deviation - odd hours, unusual volume, new devices - catching the new and the rare that no rule describes.

3.2 Three Data Planes and Cross-Plane Correlation

Detection draws on three independent viewpoints; the most valuable findings come from agreement between them.

Plane	What it sees
Host (own collectors)	Programs and their commands, files, logins, USB, signatures.
Network (Suricata)	Port scans, malicious/C2 contact, large outbound transfers, network signatures.
SIEM (Wazuh)	Brute force, privilege escalation, rootkits - already mapped to MITRE.

A scrambled command on the host is suspicious; the same machine also contacting a known criminal server is a *confirmed* command-and-control channel. Neither plane alone can conclude that. Cross-plane chains include Confirmed C2 (host + network), Scan + Brute Force (host + network, R2L), Exfiltration After Access (host + network) and SIEM + Behavioural Confirmation.

3.3 Context-Aware Detection

The system never labels a program malicious by its name. Opening PowerShell is a concern; opening PowerShell with a hidden, encoded command that downloads and runs a file is a threat. The detector weighs the full command line, the parent process, the execution path, removable-media origin, disguised file names, and the digital signature before assigning any severity.

3.4 Behavioural Feature Engineering

Each user's session is reduced to eighteen distinct behavioural numbers, each answering a different question, so the model detects 'unlike this user' rather than repeating what the rules found. Every one is collectable live on a real endpoint (Windows 4624/4663 logs plus USB drive-letter tracking, with Ubuntu and macOS equivalents), so the same feature set drives both the benchmark and live monitoring:

- **Timing:** login hour, logout hour, session length, off-hours ratio, weekend activity.
- **Intensity / volume:** activity rate, active-hours spread, process volume, file activity.
- **Style / variety:** distinct-program variety, file-to-process ratio, distinct file-type variety.
- **Authentication:** failed logins, login attempts, off-hours logins.
- **Device and network:** USB device use, removable-media activity, distinct network sources.

3.5 Anomaly Model and MITRE Mapping

Features are first standardised (zero mean, unit variance) so that low-magnitude threat indicators contribute comparably to high-volume counts, then fed to an Isolation Forest of 300 trees trained only on normal behaviour. A session's deviation is reported as an interpretable anomaly score and, for each feature, a standard-deviation distance from that user's normal - the model explaining its own reasoning. Every rule and chain carries its MITRE ATT&CK technique code (for example T1059.001 for PowerShell, T1110 for brute force, T1548 for privilege escalation).

3.6 Process Flow

The end-to-end flow is: collect → normalise into a common Event → add meaning with the context-aware detectors → summarise the session into the feature vector → judge three ways (risk, correlation, anomaly) → decide a single verdict → report with evidence and MITRE codes on the dashboard.

Chapter 4

Implementation

The system is implemented in Python and packaged as a single command-line application, *bads* (Behavior Anomaly Detection System), with a self-contained HTML dashboard.

4.1 Tools and Technologies

Tool	Purpose
Wazuh	SIEM alerts (rule-based host detection, MITRE).
Suricata	Network intrusion detection and traffic alerts.
scikit-learn	Isolation Forest and standardisation.
pandas / NumPy	Data handling and feature tables.
matplotlib	Charts (ROC, confusion matrix, dashboard).
MITRE ATT&CK;	Standardised technique labels.

4.2 Collectors and Normalisation

One collector per data source reads the raw record and a parser converts it into a common Event (timestamp, user, type, source, IP, details). The Windows collector reads the Security log (logins 4624/4625, process creation 4688 with full command line and parent, file access 4663, optional Sysmon file-creation) incrementally, and resolves USB drive letters so a program run from a stick is recognised. The Ubuntu collector reads `/var/log/auth.log` and `auditd`; the macOS collector reads the unified log. Suricata and Wazuh collectors read their JSON output (`eve.json`, `alerts.json`). After normalisation the rest of the system is OS-independent.

4.3 Detectors, Correlation and Allowlist

The context-aware detectors classify each command, file, network record and SIEM alert into normalised meanings and attach MITRE codes. A tunable allowlist suppresses the security tool's own operations and trusted administrative activity before classification, mirroring enterprise EDR exclusion policies and lowering false alarms without weakening detection. The risk engine, correlation engine and decision engine then combine into one verdict (SAFE / REVIEW / SUSPICIOUS / CRITICAL).

4.4 Model, Modes and Dashboard

Two Isolation Forest models are kept deliberately separate: a sample model for the reproducible demo and a per-machine model learned live - so live learning never degrades the reproducible attack detection. The application offers three modes: **Own** (scan this machine once), **Analyze** (the stored sample scenario) and **Live** (continuous monitoring). It ships as a per-OS demo binary

(windows-demo.exe and Linux/macOS launchers). The dashboard is a single offline HTML page showing, for every scanned session, an anomaly meter and exactly which behaviours deviated (with a recent-trend sparkline and an attack-relevance explanation on click), the model-performance metrics, the evaluation charts, and recent alerts with their offending commands and MITRE codes.

Chapter 5

Experimental Results

All results below are produced by the system itself and can be reproduced with the corresponding commands.

5.1 Results Analysis

Reproducible multi-user demonstration

On a synthetic population of 100 users (97 with a learned history, 3 new) the system correctly clears 96 ordinary users, raises one CRITICAL alert for the multi-stage attacker (a 2 a.m. USB run of a disguised executable, encoded PowerShell, credential access, plus network scanning, a Cobalt Strike beacon and a 50 MB upload, and a Wazuh alert - eleven correlation chains firing, including all four cross-plane ones), and places the three history-less users under REVIEW. Figure 5.1 shows the dashboard's behavioural-anomaly panel from this run.

Behavioral Anomaly Detection (ML / UEBA)

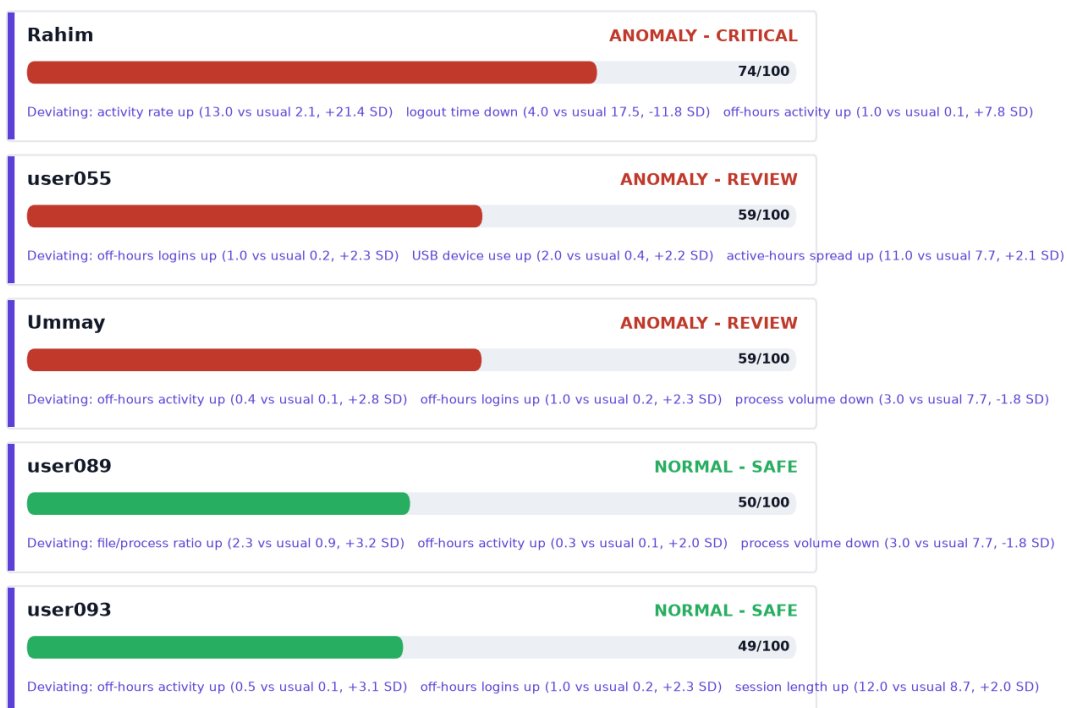


Figure 5.1: Behavioural-anomaly panel (real output). Each session shows an anomaly meter and which behaviours deviated, in standard deviations from that user's learned normal.

Detection on real recorded attacks

Replaying 137 real, publicly published Windows attack recordings (EVTX-ATTACK-SAMPLES) through the full pipeline - data the model never trained on - **136 were flagged (99.3%)**. The single missed file contains almost no evidence of the kind the system measures (a couple of events, no

command lines): an honest limitation, not a hidden one.

Standard benchmark (NSL-KDD)

Running the same Isolation Forest method on the standard NSL-KDD test set reproduces the published methodology. Figure 5.2 shows the ROC curve.

Measure	Result
ROC area (threshold-independent)	0.944
Accuracy / F1	0.848 / 0.861
DoS detection	92.4%
Probe detection	99.9%
R2L detection	44.9%
U2R detection	73.1%

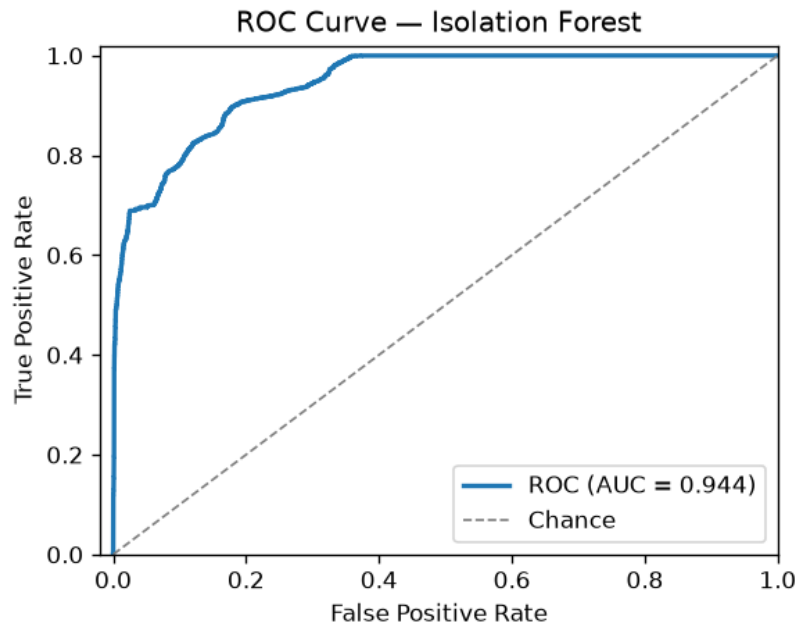


Figure 5.2: ROC curve of the Isolation Forest on NSL-KDD (KDDTest+), area 0.944.

This result is itself the argument for the whole design. Anomaly detection on network data alone is excellent on noisy attacks (DoS, Probe) but **weak on exactly the rare R2L and U2R classes** this thesis targets, because at the network-flow level they resemble ordinary traffic. That gap is precisely why the host, SIEM and correlation layers are added - and on host telemetry the privilege-escalation (U2R) and brute-force (R2L) chains fire on the real EVTX attacks, contributing to the 99.3% overall figure.

Held-out model evaluation

On a held-out set of 234 sessions - 97 held-out normal sessions plus the 137 real EVTX attacks - the model catches 136 of the 137 attacks (99% recall) at the cost of 27 false positives on the normal side, for an overall accuracy of 0.88 (Figure 5.3). The normal side here is synthetic, so these false

positives are a conservative figure; the false-positive behaviour on genuine users is measured properly on the CERT benchmark below. The near-perfect attack recall is the meaningful number: real recorded attacks are caught almost without exception.

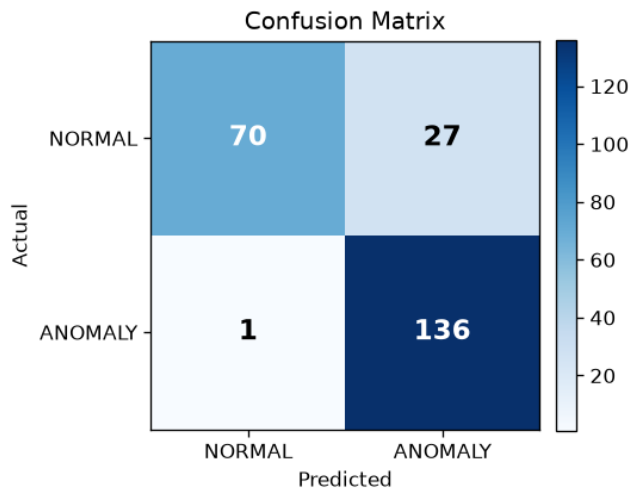


Figure 5.3: Confusion matrix on the held-out evaluation set (97 normal, 137 real attacks).

Real-scale evaluation (CERT r4.2 insider threat)

The held-out set above still draws its normal side from the project's own synthetic users. To evaluate the behavioural model on genuinely realistic data at scale, it is also run on the CERT r4.2 insider-threat benchmark (Carnegie Mellon University): 1,000 realistic users and 330,452 daily sessions, of which 986 are malicious user-days from 72 seeded insiders, labelled by the dataset's own answer key. The Isolation Forest is trained on normal sessions only and tested on held-out normals plus every malicious day, using only the live-collectable behavioural features CERT records (logon, file and USB activity; it has no process, e-mail or web logs). Figure 5.4 shows the ROC curve.

Measure	Result
ROC area (threshold-independent)	0.81
Insiders caught, top 10% reviewed	88.9% (64 of 72)
Insiders caught, top 20% reviewed	97.2% (70 of 72)
Malicious user-days, top 20% reviewed	64.0%

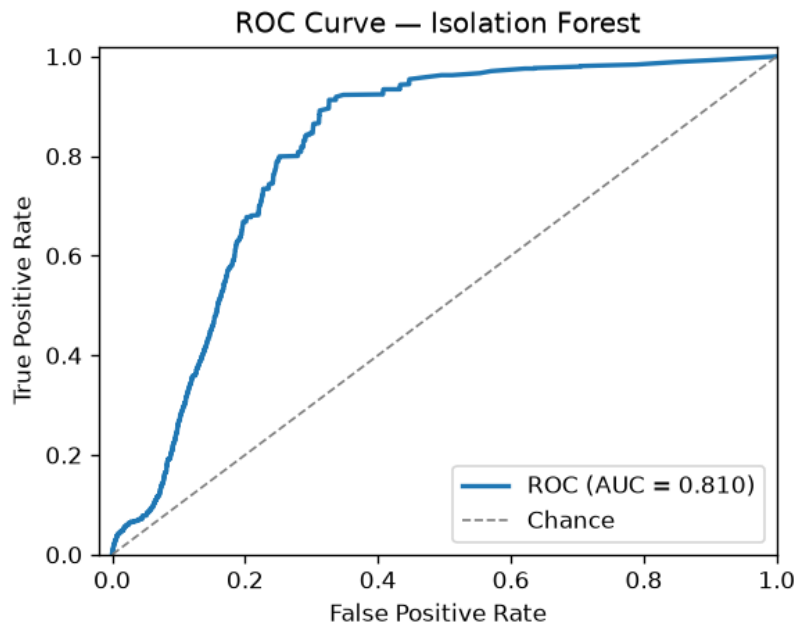


Figure 5.4: ROC curve of the behavioural Isolation Forest on CERT r4.2 (1,000 users, 330k sessions), area 0.81.

Because genuine insiders behave normally on most days, per-day detection is modest - but at an analyst budget of the top 10% most anomalous user-days the model surfaces 89% of the insiders (97% at 20%), and its ROC area of 0.81 confirms it ranks malicious activity well above normal. Raw accuracy (97%) and F1 are deliberately not used as headlines here: with malicious days only 1.5% of the data they are dominated by the majority class and would mislead. As with NSL-KDD, the modest per-day figure reflects the honest ceiling of host-behavioural signals alone on subtle insiders, and motivates the e-mail/web and cross-plane correlation layers.

5.2 Summary of the Experimental Results

Evaluation	Headline result
Sample multi-user demo (100 users)	96 clear, 1 CRITICAL (attacker), 3 REVIEW (new).
Real recorded attacks (137 EVTX)	136 detected = 99.3%.
NSL-KDD benchmark	ROC 0.944; U2R 73.1%, R2L 44.9% (netflow-only).
CERT r4.2 insider threat (1,000 users)	ROC 0.81; 89% of insiders caught in the top 10% reviewed.

The trustworthy figures are the 99.3% on real recorded attacks, the 0.944 ROC area on the public NSL-KDD benchmark, and the 0.81 ROC area over 330k real CERT sessions; the very high scores on the project's own clean sample data are expected and reported as such.

Chapter 6

Conclusions

6.1 Research Summary

This work delivered a hybrid, cross-platform intrusion-detection framework that unifies Wazuh SIEM, Suricata network monitoring, an Isolation Forest anomaly model and MITRE ATT&CK mapping in one deployable, explainable tool. By judging every session with context-aware rules, multi-stage and cross-plane correlation, and per-user behavioural anomaly detection, it improves coverage of the rare U2R and R2L classes that rule-based SIEM misses, while keeping false alarms low through allowlisting and context. Validation on real recorded attacks (99.3%) and the NSL-KDD benchmark (ROC 0.944) supports the design, and the benchmark's own weakness on R2L/U2R empirically justifies the added layers.

6.2 Future Work Plan

- Deploy live Suricata and Wazuh at scale and evaluate cross-plane correlation on production traffic.
- Extend the per-user behavioural time-series (already recorded) into longer-horizon trend and drift detection.
- Add network-behaviour anomaly features (C2 beaconing, DNS tunnelling) on top of Suricata signatures.
- Broaden dataset validation and tune the operator allowlist for specific enterprise environments.

Bibliography

- [1] S. A. Chamkar, M. Zaydi, Y. Maleh, and N. Gherabi, "Improving Threat Detection in Wazuh Using Machine Learning Techniques," J. Cybersecur. Priv., vol. 5, no. 2, p. 34, 2025.
- [2] G. A. Mills, D. K. Acquah, and R. A. Sowah, "Network Intrusion Detection and Prevention System Using Hybrid Machine Learning with Supervised Ensemble Stacking Model," J. Computer Networks and Communications, vol. 2024, 5775671, 2024.
- [3] I. Bello, O. Adeyemi, and A. Okafor, "Automation in Cybersecurity Using Machine Learning: A Case Study on Anomaly Detection with Isolation Forest," J. Technology Informatics and Engineering, vol. 4, no. 3, pp. 613-624, 2025.
- [4] S. A. R. Shah and B. Issac, "Performance Comparison of Intrusion Detection Systems and Application of Machine Learning to Snort System," Future Generation Computer Systems, vol. 80, pp. 157-170, 2018.
- [5] D. S. Ghazi et al., "Performance and Efficacy of Snort Versus Suricata in Intrusion Detection: A Benchmark Analysis," AIP Conf. Proc., vol. 3232, 020024, 2024.
- [6] A. M. Winkler and P. Sharma, "Proactive Threat Detection in Enterprise Systems Using Wazuh: A MITRE ATT&CK; Evaluation," Computers & Security, vol. 159, 104702, 2025.
- [7] H. Lv and Y. Ding, "A Hybrid Intrusion Detection System with K-Means and CNN+LSTM," EAI Endorsed Trans. Scalable Information Systems, vol. 11, no. 6, 2024.
- [8] M. Tavallaee, E. Bagheri, W. Lu, and A. A. Ghorbani, "A Detailed Analysis of the KDD CUP 99 Data Set," in Proc. IEEE CISDA, 2009, pp. 1-6.
- [9] The MITRE Corporation, "MITRE ATT&CK; Framework," <https://attack.mitre.org>.
- [10] EVTX-ATTACK-SAMPLES, a public collection of Windows event-log recordings of real attacker techniques, <https://github.com/sbousseaden/EVTX-ATTACK-SAMPLES>.